studocu

# Module No1

Computer Security and Forensic science (Kabarak University)



Scan to open on Studocu

Studocu is not sponsored or endorsed by any college or university
Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

**Module No.:** **INTE 422**

**Module Title: I.T SECURITY, AUDIT**

**Module Leader/Author:** **Dr Nelson Masese**

**Module Aims and Purpose:**

The module content will equip the learner with the basics skills of understanding the importance of IT security, ethics and audit. It aims to explore the applications of routers, switches in poorly managed security devices and will explain how companies are attacked through their connections to remote users or business partners with a less stringent security policy or implementation. It aims to illustrate how hackers, outsiders, and even disgruntled employees can threaten information security, integrity and daily business operations of organizations.

**Objectives and distinctive features:**

Introduce principles, mechanisms and implementations of computer security. Learn how attacks work and how to defend against them. Explain how to design systems to withstand such attacks explain how to perform an IT audit within a computer environment. Introduce students to ethical issues, IT legal system and media law.

**Indicative Content:**

**Security Management**: Security management concepts, Policies, standards, guidelines and procedures, Risk management.

**Access Control Systems**: Threats, vulnerabilities, and risks associated with an information system's infrastructure and the available preventive and detective measurements. Network, and Internet Security, Security measures providing availability, integrity, and confidentiality.

This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

**Cryptography**: Definitions, History, Cryptology Fundamentals, Symmetric Key Cryptosystem Fundamentals, Key Distribution and Management Issues
**Security Architecture and Models**: Software/firmware components, Open systems, Distributed systems, Protection mechanisms, Evaluation criteria, Formal security models, **Confidentiality models Operations Security**: Identifies the controls over hardware and media, and the operators and administrators with access privileges to any of these resources.
**Applications and Systems Development Security**: The software development life cycle, Database security issues, Data warehousing, Data mining.

**Business Continuity Planning and Disaster Recovery Planning**: Project scope and planning, business impact analysis, Recovery strategies, Recovery plan development, Implementation Recovery plan development, implementation and restoration.
**Law, Investigations, and Ethics**: Computer crime laws and regulations, Technologies used to investigate computer crime incidents, Laws applying to computer crimes How to determine if a crime has occurred, Preserving evidence, Liabilities under the law.
**Physical Security**: Elements involved in choosing a secure site, its design and configuration.

**Learning outcomes**

At the end of this module the students should be able to

Students gain experience in applying experimental methods to improve system security.

They learn mechanisms that can be used in the design of systems to meet security requirements. They learn the ethics of penetration studies and how to handle security intrusions Learn both the technical and human sides of security, through the classroom discussions and puzzles, helps them appreciate the need for, and implication of, security in society.

Security requires understanding policy requirements dictated by the environment in which the system is used; the technical details of the system; the restrictions of the company, the law, and other human issues; and the way in which the system will be used, so they learn how to apply techniques, tools, and skills to the solution of the complex problem of securing a system. Learn how to perform IT audits, which is separated from IT Security.

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

**Teaching and learning Strategy:**

Lectures, Presentations by members of the class, Case discussions, Tutorials, Assignments, Continuous assessment tests, Lab Practical, Library, appropriate software, manual/notes

**Assessment Strategy:**

Continuous Assessment Tests:

| | |
|---|---|
| Class test I | **10%** |
| Class test II | **10%** |
| Assignments | **10%** |
| Total module work | **30%** |
| End-of-semester examination | **70%** |
| **Total** | **100%** |

**Main texts**


1. Lawrence Oliva (2004)*Information Technology Security*,Idea Group Inc (IGI)
2. Roberta Bragg, Mark Rhodes-Ousley, Keith Strassberg(2003)*Network Security*,McGraw-Hill Professional .
3. Michael (EDT) Gertz, Leon Strous, Erik Guldentops(2002)*Integrity, Internal Control and Security in Information Systems*,Springer.
4. Linda McCarthy(2017)*IT Security*,Prentice Hall PTR


**Reference texts**


5. Gallegos Gallegos (2004) *Information Technology Control and Audit* ,CRC Press



This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

6. Benjamin Graham, David Dodd(2002)*Security Analysis*,McGraw-Hill Professional
7. Willis H Ware, Charles P Pfleeger, Shari Lawrence Pfleeger(2002)*Security in Computing*,Prentice Hall PTR

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

## INTRODUCTION

Computer data often travels from one computer to another, leaving the safety of its protected physical surroundings. Once the data is out of hand, people with bad intention could modify or forge your data, either for amusement or for their own benefit.

Information security covers the tools and processes that organizations use to protect information. This includes policy settings that prevent unauthorized people from accessing business or personal information. InfoSec is a growing and evolving field that covers a wide range of fields, from network and infrastructure security to testing and auditing.

### Information Security

InfoSec is a multidisciplinary area of study and professional activity which is concerned with the development and implementation of security countermeasures of all available types (technical, organizational, human-oriented and legal) in order to keep information in all its locations (within and outside the organization's perimeter) and, consequently, information systems, where information is created, processed, stored , transmitted and destructed, free from threats.

### Information Assurance

IA is a multidisciplinary area of study and professional activity that aims to protect the business by reducing risks associated with information and information systems using comprehensive and systematic management of security countermeasures, which is driven by risk analysis and cost-effectiveness.

**Information Assurance & Security** (IAS) knowledge area this includes all actions directed at keeping information secure as well as the management of these actions. Information Security is now no longer the sole responsibility of a discrete group of people in the company, but it is the responsibility of every employee, especially from top to bottom or bottom to the top level

This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

**Security** is "the quality or state of being secure – to be free from danger" in other words, it protects adversaries, harm, worms, and attacks, intentionally or otherwise – is the objection.

Security is often achieved by different means of several planning and strategies undertaken simultaneously or used in combination with one another

Information security protects sensitive information from unauthorized activities, including inspection, modification, recording, and any disruption or destruction. The goal is to ensure the safety and privacy of critical data such as customer account details, financial data or intellectual property.

The consequences of security incidents include theft of private information, data tampering, and data deletion. Attacks can disrupt work processes and damage a company's reputation, and also have a tangible cost.

Threat and attack are two important events from a security perspective. It is really important to understand the difference between both from the perspective of network security.

A **Threat** is a possible security violation that might exploit the vulnerability of a system or asset. The origin of threat may be accidental, environmental (natural disaster), human negligence or human failure. Difference types of security threats are interruption, interception, fabrication and modification.

**Attack** is an deliberate unauthorized action on a system or asset. Attack can be classified as active and passive attack. An attack will have a motive and will follow a method when opportunity arise.

**Specialized areas of security**

Achieving the appropriate level of security for an organization also requires a multifaceted system. A success organization should have the following multiple layers of security in place to protect its operations;

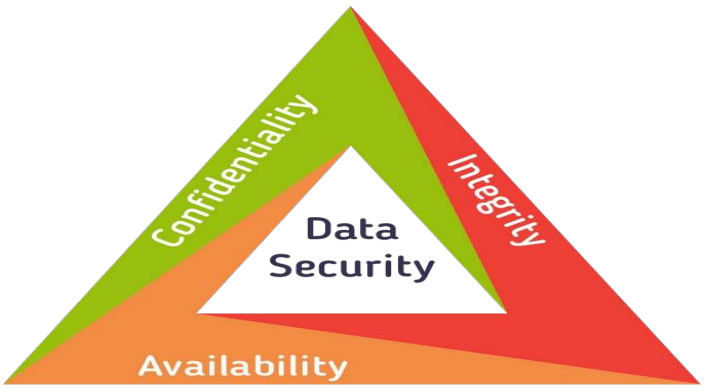
- **Physical Security:** It is to protect physical items, objects, or areas from unauthorized access and misuse

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

- **Personal Security:** It is to protect the individual or group of individuals who are authorized to access the organization and its operations
- **Operation Security**: It is to protect the details of the operation or a series of activities.
- **Communication Security:** It is to communications media, technology, and content.
- **Network Security:** It is to protect networking components, connections, and contents.
- **Information Security:** it is the protection of information and its critical elements (Confidentiality, Integrity, and availability), including the systems and hardware that use, store, and transmit that information through the application of policy, education, technology, training, and awareness program.

**Principles of Information Security**

The basic tenets of information security are confidentiality, integrity and availability. Every element of the information security program must be designed to implement one or more of these principles. Together they are called the CIA Triad.




**Confidentiality**

Confidentiality measures are designed to prevent unauthorized disclosure of information. The purpose of the confidentiality principle is to keep personal information private and to ensure that

This document is available on studocu
Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

it is visible and accessible only to those individuals who own it or need it to perform their organizational functions.

**Integrity**

Consistency includes protection against unauthorized changes (additions, deletions, alterations, etc.) to data. The principle of integrity ensures that data is accurate and reliable and is not modified incorrectly, whether accidentally or maliciously.

**Availability**

Availability is the protection of a system's ability to make software systems and data fully available when a user needs it (or at a specified time). The purpose of availability is to make the technology infrastructure, the applications and the data available when they are needed for an organizational process or for an organization's customers.

***Others include***

- **Non repudiation –** means one party cannot deny receiving a message or a transaction nor can the other party deny sending a message or a transaction. For example in cryptography it is sufficient to show that message matches the digital signature signed with sender's private key and that sender could have a sent a message and nobody else could have altered it in transit. Data Integrity and Authenticity are pre-requisites for Non repudiation.

- **Authenticity –** means verifying that users are who they say they are and that each input arriving at destination is from a trusted source. This principle if followed guarantees the valid and genuine message received from a trusted source through a valid transmission
- **Accountability –** means that it should be possible to trace actions of an entity uniquely to that entity. For example as we discussed in Integrity section Not every employee should be allowed to do changes in other employees data.

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

**Security Attacks, Mechanisms &Services**

To assess the security needs of an organization effectively, the manager responsible for security needs some systematic way of defining the requirements for security and characterization of approaches to satisfy those requirements. One approach is to consider three aspects of information security:

**Security attack** – Any action that compromises the security of information owned by an

organization.

**Security mechanism** – A mechanism that is designed to detect(identify), prevent or recover from a security attack.

**Security service** – A service that enhances the security of the data processing systems and the

information transfers of an organization. The services are intended to counter security attacks and

they make use of one or more security mechanisms to provide the service.

**SECURITY ATTACKS**

There are four general categories of attack which are listed below.

**Interruption**

An asset of the system is destroyed or becomes unavailable or unusable. This is an attack on

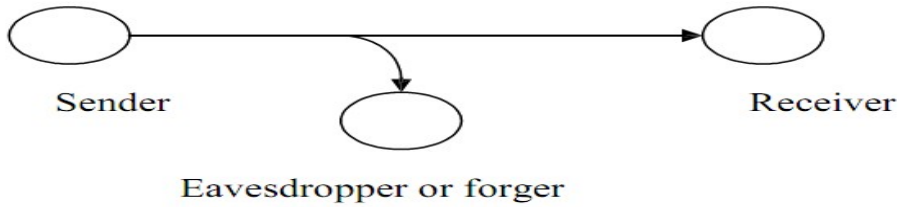
availability e.g., destruction of piece of hardware, cutting of a communication line or

Disabling of file management system.

**Interception**

An unauthorized party gains access to an asset. This is an attack on confidentiality.

Unauthorized party could be a person, a program or a computer.e.g., wire tapping to capture data in the network, illicit copying of files.

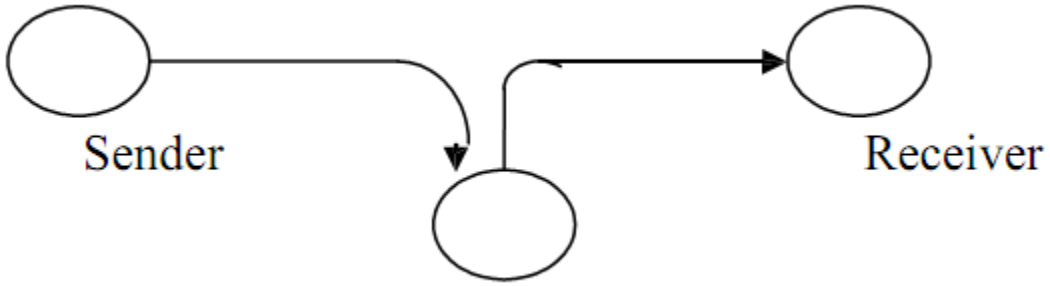



This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

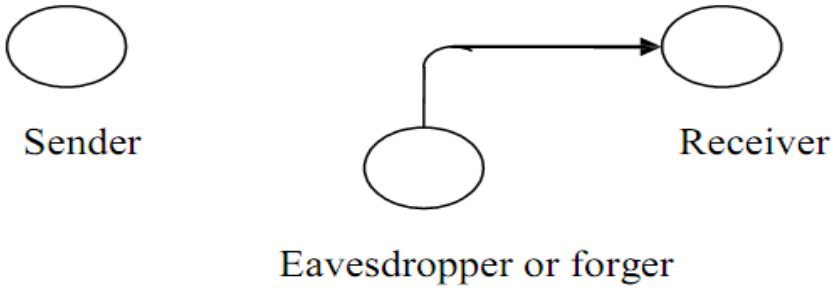
**Modification**

An unauthorized party not only gains access to but tampers with an asset. This is an attack on integrity. e.g., changing values in data file, altering a program, modifying the contents of messages being transmitted in a network.




**Fabrication**

An unauthorized party inserts counterfeit objects into the system. This is an attack on authenticity. e.g., insertion of spurious message in a network or addition of records to a file.




Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

**Cryptographic Attacks**

**Passive Attacks**

Passive attacks are in the nature of eavesdropping on, or monitoring of, transmissions. The goal of the opponent is to ***obtain information that is being transmitted***. Passive attacks are of two types:

**Release of message contents:** A telephone conversation, an e-mail message and a transferred file may contain sensitive or confidential information. We would like to prevent the opponent from learning the contents of these transmissions.

**Traffic analysis:** If we had encryption protection in place, an opponent might still be able to observe the pattern of the message. The opponent could determine the location and identity of communication hosts and could observe the frequency and length of messages being exchanged. This information might be useful in guessing the nature of communication that was taking place.

Passive attacks are very difficult to detect because they do not involve any alteration of data.

However, it is feasible to prevent the success of these attacks.

**Active attacks**

These attacks involve some ***modification*** of the data stream or the creation of a false stream. These attacks can be classified in to four categories:

**Masquerade** – One entity pretends to be a different entity.

**Replay** – involves passive capture of a data unit and its subsequent transmission to produce an unauthorized effect.

**Modification of messages** – Some portion of message is altered or the messages are delayed or recorded, to produce an unauthorized effect.

**Denial of service** – Prevents or inhibits the normal use or management of communication facilities. Another form of service denial is the disruption of an entire network, either by disabling the network or overloading it with messages so as to degrade performance.

This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

It is quite difficult to prevent active attacks absolutely, because to do so would require physical protection of all communication facilities and paths at all times. Instead, the goal is to detect them and to recover from any disruption or delays caused by them.

**SECURITY MECHANISMS**

One of the most specific security mechanisms in use is cryptographic techniques.

Encryption or encryption-like transformations of information are the most common means of providing security. Some of the mechanisms are

1 Encipherment 2 Digital Signature 3 Access Control

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

**SECURITY SERVICES**

The classification of security services are as follows:

**Confidentiality:** Ensures that the information in a computer system a n d transmitted information are accessible only for reading by authorized parties. E.g. Printing, displaying and other forms of disclosure.

**Authentication:** Ensures that the origin of a message or electronic document is correctly identified, with an assurance that the identity is not false.

**Integrity:** Ensures that only authorized parties are able to modify computer system assets and transmitted information. Modification includes writing, changing status, deleting, creating and delaying or replaying of transmitted messages.

**Non repudiation:** Requires that neither the sender nor the receiver of a message be able to deny the transmission.

**Access control:** Requires that access to information resources may be controlled by or the target system.

**Availability:** Requires that computer system assets be available to authorized parties when needed.

**Threat** - a threat is a method of triggering a risk event that is dangerous. It is also the potential for a threat-source to exercise (accidentally trigger or intentionally exploit) a specific vulnerability.

**Risk** - a risk is a possible event which could cause a loss

**Vulnerability** - a weakness in a target that can potentially be exploited by a security threat. It can also mean a flaw or weakness in system security procedures, design, implementation or internal controls that could be exercised (accidentally triggered or intestinally exploited) and could result in a security breach or a violation of a system's security policy.

**Exploit** - a vulnerability that has been triggered by a threat - a risk of (100%)

**Defense in depth** - never rely on one single security measure alone

**Likelihood** – The probability that a potential vulnerability may be exercised within the construct of an associated threat environment.

This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

## Proactive Vs. Reactive  Security

***Proactive Security***

A proactive security approach prevents major incidents before they happen. Preventative measures taken by a company anticipate potential situations and save the firm from experiencing devastating events that can lead to crippling losses from theft, fire or natural disaster.

In addition, the physical manifestations of a proactive security system such as signs, cameras and passwords act as visible deterrents to thieves, vandals and hackers.

***Examples of Proactive Security***

Proactive security measures can range from a simple padlock to a sophisticated security system. They can be physical barriers, such as heavy doors or fireproof file cabinets, or electronic countermeasures, such as pressure sensors, surveillance cameras and keycard readers.

Proactive cyber security tactics include: Threat hunting

- Ethical hacking
- Proactive network and endpoint monitoring
- Staff training

Proactive security systems can be unmanned or can involve a full staff of security professionals. Many companies employ proactive security procedures on both their physical assets and their sensitive data, such as intellectual property and customer records.

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

## *Reactive Security*

The reactive security approach calls for companies to respond to past and present threats, rather than anticipate future dangers. When the company falls victim to a threat, the owners determine the level of the threat, assess the amount of the damage and install measures to prevent such an event from reoccurring.

Since no business can anticipate every possible threat and many do not have the resources to install proactive measures to counter unanticipated threats, many companies employ a reactive security approach.

***Examples of Reactive Security***

Security companies, such as those that offer 24-hour monitoring, function more as reactive agents than as proactive measures.

These companies provide personnel to patrol a facility, monitor computer activity and watch live feeds from security cameras. In the event that a security incident occurs, they step in and attempt to stop the perpetrators or contact local law enforcement agencies.

The visibility of security guards serves a proactive function, but often they act in a reactive capacity.company's reactive cyber security tactics might include:

- Firewalls
- Antivirus or anti-malware software
- Password protections
- Spam filters
- Ad blockers

Explain 10 types of threats in computer n/w

Define a firewall, explain in detail 5 types of firewalls and when they are applicable

Explain the need of user training before using any system

This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

**INFORMATION SECURITY POLICY**

An information security policy is a set of rules and guidelines that dictate how information technology (IT) assets and resources should be used, managed, and protected.

It applies to all users in an organization or its networks as well as all digitally stored information under its authority. An information security policy addresses threats and defines strategies and procedures for mitigating IT security risks.

There are many components of an information security policy. Fundamental elements include:

(i) Information security roles and responsibilities

(ii) Minimum security controls

(iii) Repercussions for breaking information security policy rules

*Summary of Definition*

*An information security policy is an aggregate of directives, regulations, rules, and practices that prescribes how an organization manages, protects, and distributes information*

To be effective, an information security policy should:

(i) Cover end-to-end security processes across the organization
(ii) Be enforceable and practical
(iii) Be regularly updated in response to business needs and evolving threats
(iv) Be focused on the business goals of your organization

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

Important outcomes of an information security policy include:

**Facilitates the confidentiality, integrity, and availability of data**

A robust policy standardizes processes and rules to help organizations protect against threats to data confidentiality, integrity, and availability.

**Reduces the risk of security incidents**

An information security policy outlines procedures for identifying, assessing, and mitigating security vulnerabilities and risks. It also explains how to quickly respond to minimize damage in the event of a security incident.

**Executes security programs across an organization**

To ensure successful execution, a security program needs an information security policy to provide the framework for operationalizing procedures

**Provides clear statement of security policy to third parties**

The policy summarizes the organization's security posture and details how it protects IT assets and resources. It allows organizations to quickly respond to third-party (e.g., customers', partners', auditors') requests for this information.

**Helps to address regulatory compliance requirements**

The process of developing an information security policy helps organizations identify gaps in security protocols relative to regulatory requirements.

## Information Security Policy Best Practices

**Read** : *https://www.egnyte.com/guides/governance/information-security- policy#:~:text=An%20information%20security%20policy%20is,stored%20information%20under%20its%20authority.*

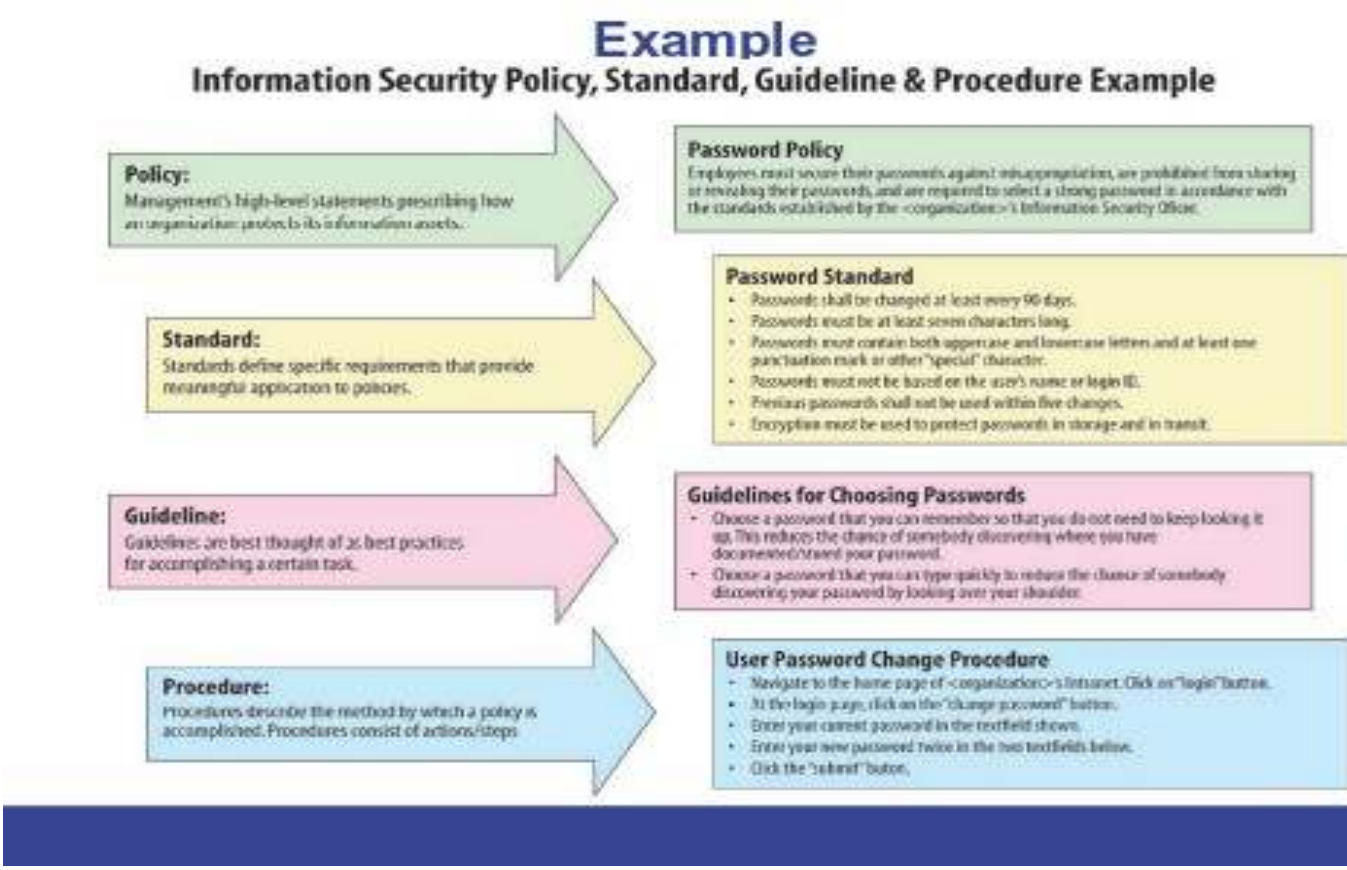
This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

***Security policy components***

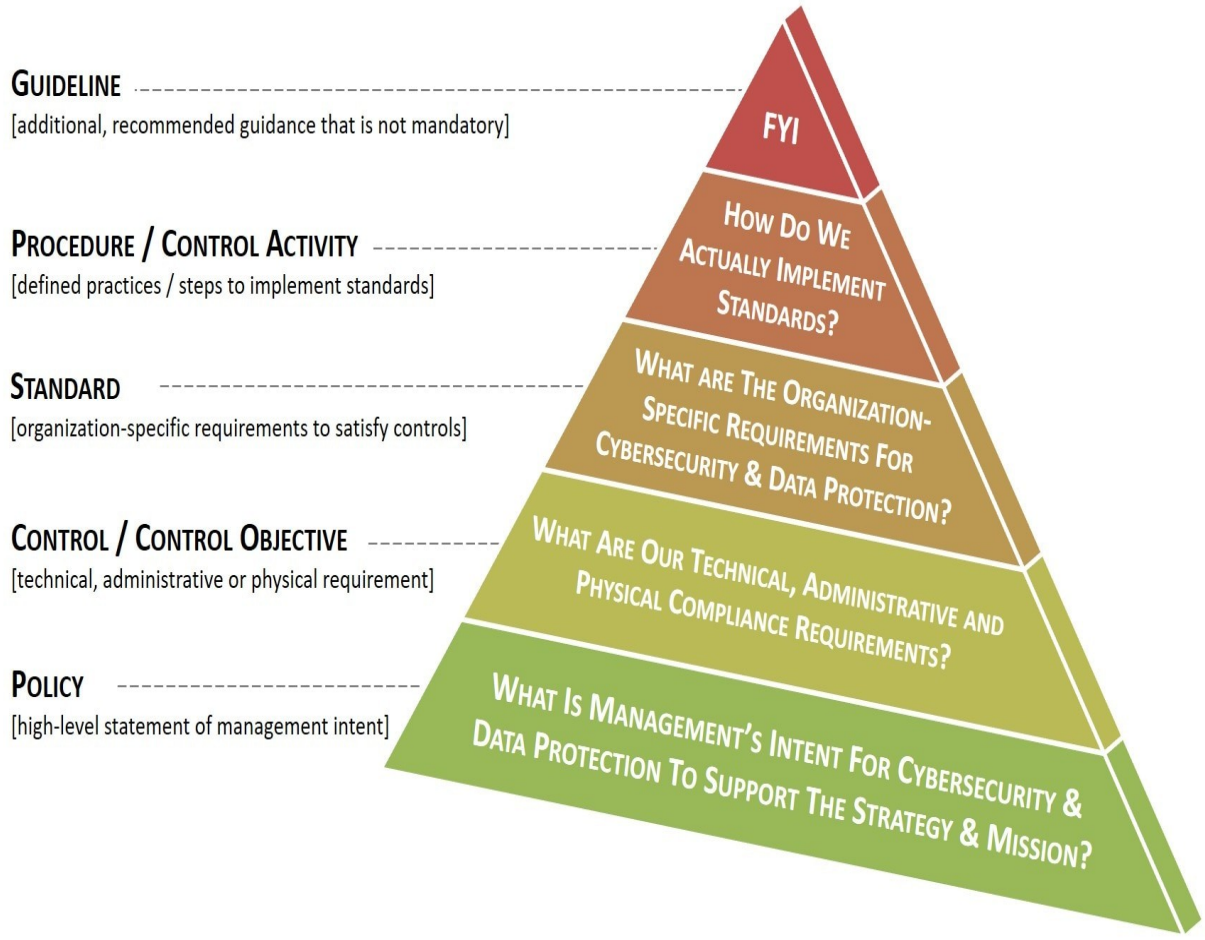
1. **Policies** are established by an organization's corporate leadership establishes "management's intent" for cybersecurity and data protection requirements that are necessary to support the organization's overall strategy and mission;
   Controls / Control Objectives identify the technical, administrative and physical protections that are generally tied to a law, regulation, industry framework or contractual obligation;
2. **Standards** provide organization-specific, quantifiable requirements for cybersecurity and data protection;
3. **Procedures** (also known as Control Activities) establish the defined practices or steps that are performed to meet to implement standards and satisfy controls / control objectives; and
4. **Guidelines** are additional guidance that is recommended, but not mandatory.

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)




This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)




**Key Elements of an Information Security Policy**

An information security policy can be as broad as you want it to be. It can cover IT security and/or physical security, as well as social media usage, lifecycle management and security training. In general, an information security policy will have these nine key elements:

**1. Purpose**

Outline the purpose of your information security policy which should:

- Preserve your organization's information security.
- Detect and preempt information security breaches caused by third-party vendors, misuse of networks, data, applications, computer systems and mobile devices.
- Protect the organization's reputation
- Uphold ethical, legal and regulatory requirements
- Protect customer data and respond to inquiries and complaints about non-compliance of security requirements and data protection

**2. Audience**

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

Define who the information security policy applies to and who it does not apply to. You may be tempted to say that third-party vendors are not included as part of your information security policy.

This may not be a great idea. Third-party, fourth-party risk and vendor risk should be accounted for. Whether or not you have a legal or regulatory duty to protect your customer's data from third-party data breaches and data leaks isn't important. Customers may still blame your organization for breaches that were not in your total control and the reputational damage can be huge.

**3. Information Security Objectives**

These are the goals management has agreed upon, as well as the strategies used to achieve them.

In the end, information security is concerned with the CIA triad:

- **Confidentiality:** data and information are protected from unauthorized access
- **Integrity:** Data is intact, complete and accurate
- **Availability:** IT systems are available when needed

**4. Authority and Access Control Policy**

This part is about deciding who has the authority to decide what data can be shared and what can't. Remember, this may not be always up to your organization. For example, if you are the CSO at a hospital.

An access control policy can help outline the level of authority over data and IT systems for every level of your organization. It should outline how to handle sensitive information, who is responsible for security controls, what access control is in place and what security standards are acceptable.

It may also include a network security policy that outlines who can have access to company networks and servers, as well as what authentication requirements are needed including strong password requirements, biometrics, ID cards and access tokens.

In some cases, employees are contractually bound to comply with the information security policy before being granted access to any information systems and data centers.

5. Data Classification

An information security policy must classify data into categories. A good way to classify the data is into five levels that dictate an increasing need for protection:

1. **Level 1:** Public information
2. **Level 2:** Information your organization has chosen to keep confidential but disclosure would not cause material harm

This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

3. **Level 3:** Information has a risk of material harm to individuals or your organization if disclosed
4. **Level 4:** Information has a high risk of causing serious harm to individuals or your organization if disclosed
5. **Level 5:** Information will cause severe harm to individuals or your organization if disclosed

In this classification, levels 2-5 would be classified as confidential information and would need some form of protection.

Read our full guide on data classification here.

**6. Data Support and Operations**

Once data has been classified, you need to outline how data is each level will be handled. There are generally three components to this part of your information security policy:

1. **Data protection regulations:** Organizations that store personally identifiable information (PII) or sensitive data must be protected according to organizational standards, best practices, industry compliance standards and regulation
2. **Data backup requirements:** Outlines how data is backed up, what level of encryption is used and what third-party service providers are used
3. **Movement of data:** Outlines how data is communicated. Data that is deemed classified in the above data classification should be securely communicated with encryption and not transmitted across public networks to avoid man-in-the-middle attacks

7. **Security Awareness Training**

A perfect information security policy that no one follows is no better than having no policy at all. You need your staff to understand what is required of them. Training should be conducted to inform employees of security requirements, including data protection, data classification, access control and general security threats.

Security training should include:

- **Social engineering:** Teach your employees about phishing, spearphishing and other common social engineering cyber attacks
- **Clean desk policy:** Laptops should be taken home and documents shouldn't be left on desks at the end of the work day
- **Acceptable usage:** What can employees use their work devices and Internet for and what is restricted?
-

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

**8. Responsibilities and Duties of Employees**

This is where you operationalize your information security policy. This part of your information security policy needs to outline the owners of:

- Security programs
- Acceptable use policies
- Network security
- Physical security
- Business continuity
- Access management
- Security awareness
- Risk assessments
- Incident response
- Data security
- Disaster recovery
- Incident management

**9. Other Items an ISP May Include**

Virus protection procedure, malware protection procedure, network intrusion detection procedure, remote work procedure, technical guidelines, consequences for non-compliance, physical security requirements, references to supporting documents

**Create social media usage policy for kabarak university**

**Risk Management**

A risk is nothing but intersection of assets, threats and vulnerability.

$$A+T+V = R$$

The main components of Risk Assessment are:

(i) Threats

(ii) Vulnerability

(iii) Impact (i.e. potential loss)

This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

(iv) Likelihood of occurrence (i.e. the probability that an event – threat successful exploit of a vulnerability – will occur)

- **Threats** is anything that can exploit a vulnerability accidentally or intentionally and destroy or damage an **asset**. Asset can be anything people, property or information. Asset is what we are trying to protect and a threat is what we are trying to protect against. **Vulnerability** means gap or weakness in our protection efforts.
- **Threat Source** is a method to exploit a vulnerability or a situation either intentionally or unintentionally. For example a Malicious Software to which a virus or worm attaches to spread itself in the system and to others computer via email containing either virus as a attachment or as a link

***The complete process of handling Risk can be divided into following stages***

**1. Context Establishment –**

In this step information about the organization and basic *criteria, purpose, scope and boundaries of risk management activities are obtained*. In addition to this data, it is important to gather details about the organization in charge of risk management activities.
*Organization's mission, values, structure, strategy, locations and cultural environment are studied to have a deep understanding* of it's scope and boundaries.
The constraints (budgetary, cultural, political, technical) of the organization are to be collected and documented as guide for next steps.

The main role inside organization in charge of risk management activities can be seen as:

1. Senior Management
2. Chief information officer (CIO)
3. System and Information owners
4. the business and functional managers
5. the Information System Security Officer (ISSO) or Chief information security officer (CISO)
6. IT Security Practitioners

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

7. Security Awareness Trainers

**2. Risk Assessment –**

Risk Management is a recurrent activity, on the other hand Risk assessment is executed at discrete points and until the performance of the next assessment.

Risk Assessment is the process of evaluating known and postulated threats and vulnerabilities to determine expected loss. It also includes establishing the degree of acceptability to system operations.

Risk Assessment receives input and output from Context establishment phase and output is the list of assessed risk risks, where risks are given priorities as per risk evaluation criteria.

1. **Risk Identification –**

   In this step we identify the following:

   (i) assets
   (ii) threats
   (iii) existing and planned security measures
   (iv) vulnerabilities
   (v) consequence
   (vi) related business processes

   Thus output includes the following:

   (i) list of asset and related business processes with associated list of threats, existing and planned security measures
   (ii) list of vulnerabilities unrelated to any identified threats
   (iii) list of incident scenarios with their consequences

2. **Risk Estimation –**

   There are 2 methods for Risk Assessment:

   **1. Quantitative Risk Assessment –** This methodology is not mostly used by the organizations except for the financial institutions and insurance companies. Quantitative

This document is available on studocu
Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

risk is mathematically expressed as Annualised Loss Expectancy (ALE). ALE is the expected monetary loss that can be expected for an asset due to a risk being realised over a one-year period.

***ALE= SLE * ARO***

**Single Loss Expectancy** (SLE) is the value of a single loss of the asset. This may or may not be the entire asset. This is the impact of the loss. **Annualised Rate of Occurrence** (ARO) is how often the loss occurs. This is the likelihood.

**2. Qualitative Risk Assessment –** Qualitative Risk Assessment defines likelihood, impact values and risk in subjective terms, keeping in mind that likelihood and impact values are highly uncertain. Qualitative risk assessments typically give risk results of "High", "Moderate" and "Low". Following are the steps in Qualitative Risk Assessment:

1. **Identifying Threats:** Threats and Threat-Sources must be identified. Threats should include threat-source to ensure accurate estimation. It is important to compile a list of all possible threats that are present across the organization and use this list as the basis for all risk management activities. Some of the examples of threat and threat-source are:
    (i) Natural Threats- floods, earthquakes etc.
    (ii) Human Threats- virus, worms etc.
    (iii) Environmental Threats- power failure, pollution etc.
2. **Identifying Vulnerabilities:** Vulnerabilities are identified by numerous means. Some of the tools are:
    1. Vulnerability Scanners – This is the software the compare the operating system or code for flaws against the database of flaw signatures.
    2. Penetration Testing – Human Security analyst will exercise threats against the system including operational vulnerabilities like Social Engineering.
    3. Audit of Operational and Management Controls – Operational and management controls are reviewed by comparing the current documentation to best practices.

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

3. **Relating Threats to Vulnerabilities:** This is the most difficult and mandatory activity in Risk Assessment. T-V pair list is established by reviewing the vulnerability list and pairing a vulnerability with every threat that applies, then by reviewing the threat list and ensuring that all the vulnerabilities that that threat-action/threat can act against have been identified.
4. **Defining Likelihood:** Likelihood is the probability that a threat caused by a threat-source will occur against a vulnerability. Sample Likelihood definitions can be like:

(i) Low -0-30% chance of successful exercise of Threat during a one year period

(ii) Moderate – 31-70% chance of successful exercise of Threat during a one year period

(iii) High – 71-100% chance of successful exercise of Threat during a one year period

This is just a sample definitions. Organization can use their own definition like Very Low, Low, Moderate, High, Very High.

5. **Defining Impact:** Impact is best defined in terms of impact upon confidentiality, integrity and availability. Sample definitions for impact are as follows:

| | Confidentiality | Integrity | Availability |
|---|---|---|---|
| Low<br>0-3 | Loss of Confidentiality leads to **Limited effect** on organization | Loss of Integrity leads to **Limited effect** on organization | Loss of Availability leads to **Limited effect** on organization |
| Mediu<br>m<br>4-7 | Loss of Confidentiality leads to **Serious effect** on organization | Loss of Integrity leads to **Serious effect** on organization | Loss of Availability leads to **Serious effect** on organization |

This document is available on studocu
Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

| | Confidentiality | Integrity | Availability |
|---|---|---|---|
| High<br>8-10 | Loss of Confidentiality leads to **Severe effect** on organization | Loss of Integrity leads to **Severe effect** on organization | Loss of Availability leads to **Severe effect** on organization |

6. **Assessing Risk:** Assessing risk is the process to determine the likelihood of the threat being exercised against the vulnerability and the resulting impact from a successful compromise.

**3. Risk Evaluation –** The risk evaluation process receives as input the output of risk analysis process. It first compares each risk level against the risk acceptance criteria and then prioritise the risk list with risk treatment indications.

**3. Risk Mitigation/ Management –**

Risk Mitigation involves prioritizing, evaluating, and implementing the appropriate risk-reducing controls recommended from the risk assessment process. Since eliminating all risk in an organization is close to impossible thus, it is the responsibility of senior management and functional and business managers to use the least-cost approach and implement the most appropriate controls to decrease risk to an acceptable level.

There are 6 steps in Risk Mitigation.

1. **Risk Assumption:** This means to accept the risk and continue operating the system but at the same time try to implement the controls.
2. **Risk Avoidance:** This means to eliminate the risk cause or consequence in order to avoid the risk for example shutdown the system if the risk is identified.
3. **Risk Limitation:** To limit the risk by implementing controls that minimize the adverse impact of a threat's exercising a vulnerability (e.g., use of supporting, preventive, detective controls)

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

4. **Risk Planning:** To manage risk by developing a risk mitigation plan that prioritizes, implements, and maintains controls
5. **Research and Acknowledgement:** In this step involves acknowledging the vulnerability or flaw and researching controls to correct the vulnerability.
6. **Risk Transference:** This means to transfer the risk to compensate for the loss for example purchasing insurance guarantees not 100% in all cases but atleast some recovery from the loss.

**4. Risk Communication –**

The main purpose of this step is to communicate, give an understanding of all aspects of risk to all the stakeholder's of an organization. Establishing a common understanding is important, since it influences decisions to be taken.

**5. Risk Monitoring and Review –**

Security Measures are regularly reviewed to ensure they work as planned and changes in the environment don't make them ineffective. With major changes in the work environment security measures should also be updated.Business requirements, vulnerabilities and threats can change over the time. Regular audits should be scheduled and should be conducted by an independent party.

**6. IT Evaluation and Assessment –**

Security controls should be validated. Technical controls are systems that need to tested and verified. Vulnerability assessment and Penetration test are used for verifying status of security controls. Monitoring system events according to a security monitoring strategy, an incident response plan and security validation and metrics are fundamental activities to assure that an optimal level of security is obtained.

This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

*Cryptography* ***The art or science encompassing the principles and methods of transforming an intelligible message into one that is unintelligible, and then retransforming that message back to its original form Plaintext The original intelligible message***

**Cipher text** The transformed message

**Cipher** An algorithm for transforming an intelligible message into one that is unintelligible by transposition and/or substitution methods

**Key** Some critical information used by the cipher, known only to the sender& receiver

Encipher (encode) The process of converting plaintext to cipher text using a cipher and a key

**Decipher (decode)** the process of converting cipher text back into plaintext using a cipher and a key

**Cryptanalysis** The study of principles and methods of transforming an unintelligible message back into an intelligible message without knowledge of the key. Also called code breaking

Cryptology Both cryptography and cryptanalysis

**Code** An algorithm for transforming an intelligible message into an unintelligible one using a code-book

**Cryptography**

Cryptographic systems are generally classified along 3 independent dimensions:

**Type of operations used for transforming plain text to cipher text**

All the encryption algorithms are based on two general principles: substitution, in which each element in the plaintext is mapped into another element, and transposition, in which elements in the plaintext are rearranged.

**The number of keys used**

If the sender and receiver uses same key then it is said to be symmetric key (or) single key (or) conventional encryption.

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

If the sender and receiver use different keys then it is said to be private key encryption.

**The way in which the plain text is processed**

A block cipher processes the input and block of elements at a time, producing output block for each input block.

A **stream cipher** processes the input elements continuously, producing output element one at a time, as it goes along.

**Cryptanalysis**

The process of attempting to discover X or K or both is known as cryptanalysis. The strategy used by the cryptanalysis depends on the nature of the encryption scheme and the information available to the cryptanalyst.

There are various types of cryptanalytic attacks based on the amount of information known to the cryptanalyst.

**Cipher text only –** A copy of cipher text alone is known to the cryptanalyst.

**Known plaintext –** The cryptanalyst has a copy of the cipher text and the corresponding plaintext.

**Chosen plaintext –** The cryptanalysts gains temporary access to the encryption machine. They cannot open it to find the key, however; they can encrypt a large number of suitably chosen plaintexts and try to use the resulting cipher texts to deduce the key.

**Chosen cipher text –** The cryptanalyst obtains temporary access to the decryption machine, uses it to decrypt several string of symbols, and tries to use the results to deduce the key.

This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

## STEGANOGRAPHY

A plaintext message may be hidden in any one of the two ways. The methods of steganography conceal the existence of the message, whereas the methods of cryptography render the message unintelligible to outsiders by various transformations of the text.

A simple form of steganography, but one that is time consuming to construct is one in which an arrangement of words or letters within an apparently innocuous text spells out the real message. e.g.,

(i) the sequence of first letters of each word of the overall message spells out the real (Hidden) message.

(ii) Subset of the words of the overall message is used to convey the hidden message.

Various other techniques have been used historically, some of them are

Character marking – selected letters of printed or typewritten text are overwritten in pencil. The marks are ordinarily not visible unless the paper is held to an angle to bright light.

Invisible ink – a number of substances can be used for writing but leave no visible trace until heat

or some chemical is applied to the paper.

**Pin punctures** – small pin punctures on selected letters are ordinarily not visible unless the

paper is held in front of the light. Typewritten correction ribbon – used between the lines typed

with a black ribbon, the results of typing with the correction tape are visible only under a strong

light.

**Drawbacks of steganography**

Requires a lot of overhead to hide a relatively few bits of information.

Once the system is discovered, it becomes virtually worthless.

**Symmetric and public key algorithms**

Encryption/Decryption methods fall into two categories.

Symmetric key

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

Public key

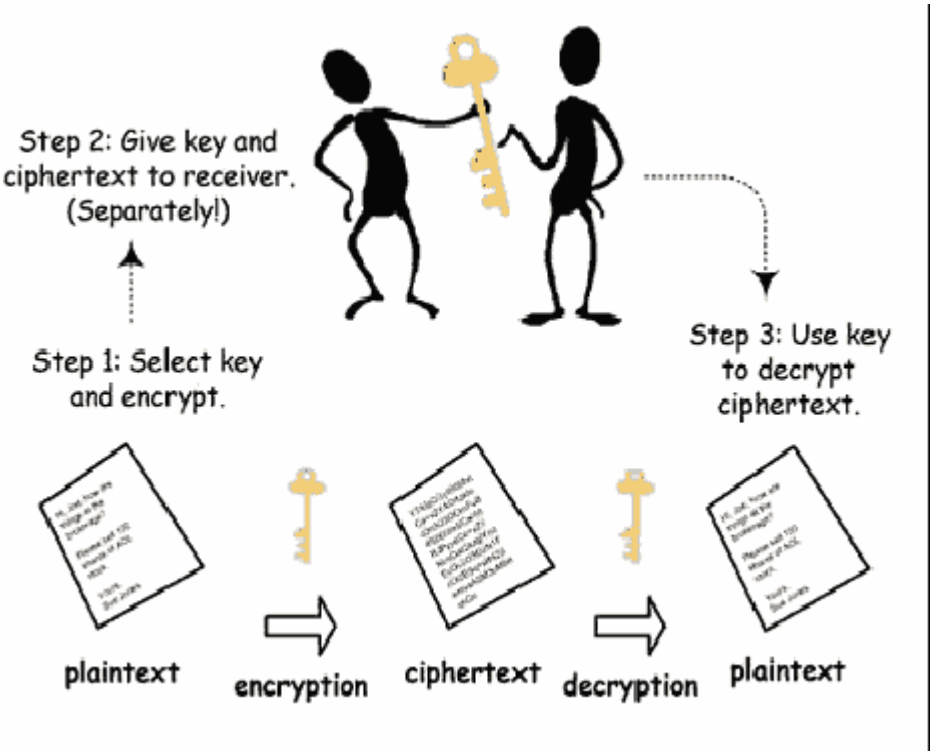
In symmetric key algorithms, the encryption and decryption keys are known both to sender and receiver. The encryption key is shared and the decryption key is easily calculated from it.

In many cases, the encryption and decryption keys are the same.

In public key cryptography, encryption key is made public, but it is computationally infeasible to find the decryption key without the information known to the receiver.

1. Symmetric·Key Cryptography

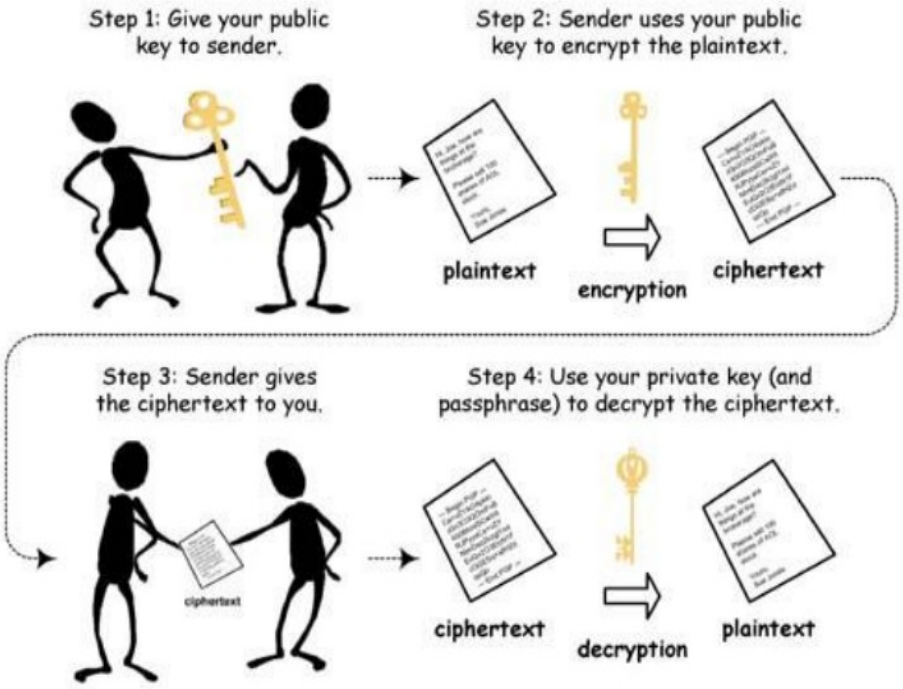
In symmetric-key cryptography, the same key is used by both parties. The sender uses this key and an encryption algorithm to encrypt data; the receiver uses the same key and the corresponding decryption algorithm to decrypt the data.

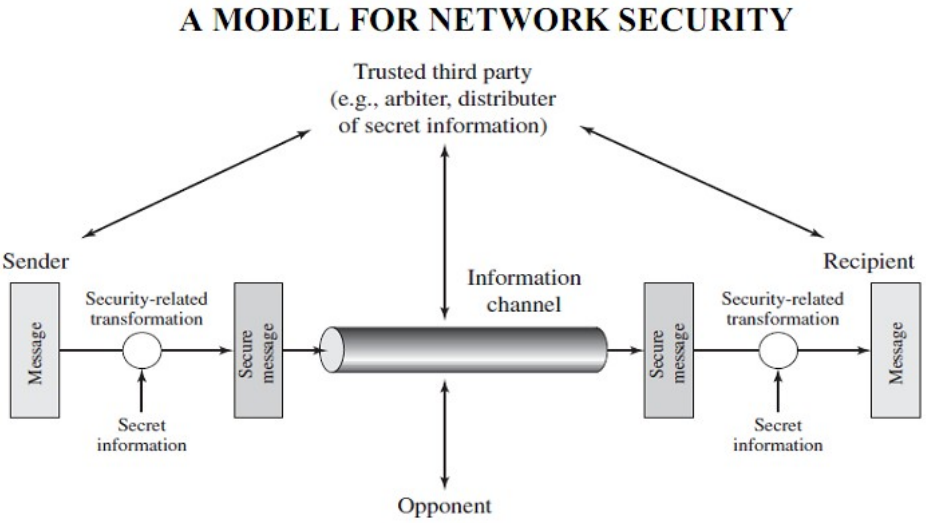



2. Asymmetric-Key Cryptography:

This document is available on studocu
Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

In asymmetric or public-key cryptography, there are two keys: a private key and a public key. The private key is kept by the receiver. The public key is announced to the public.




Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

A message is to be transferred from one party to another across some sort of internet/ network. The two parties, who are the principals in this transaction, must cooperate for the exchange to take place.

A logical information channel is established by defining a route through the internet from source

to destination and by the cooperative use of communication protocols (e.g., TCP/IP) by the

two principals.

**Using this model requires us to:**

– design a suitable algorithm for the security transformation

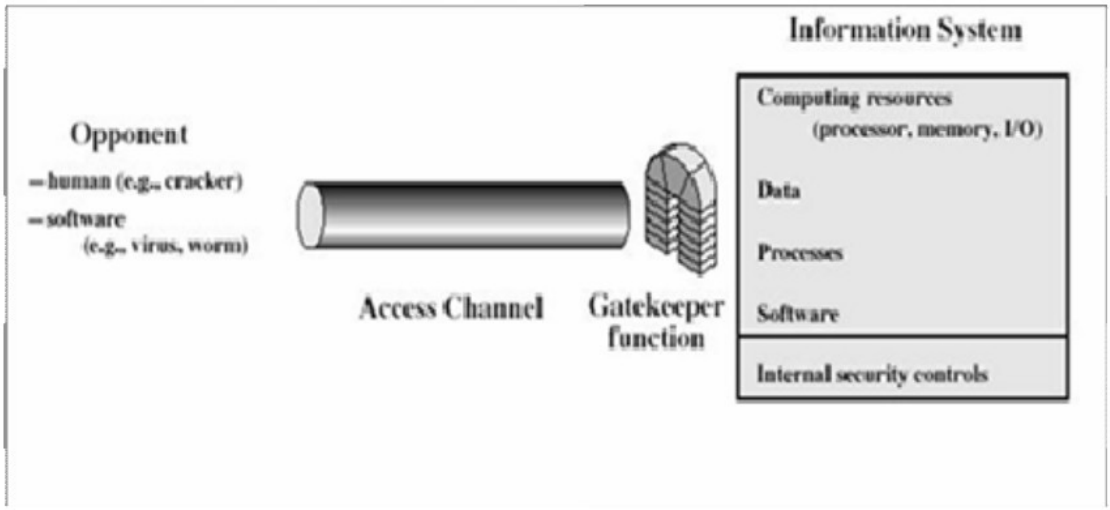
– generate the secret information (keys) used by the algorithm

– develop methods to distribute and share the secret information

– specify a protocol enabling the principals to use the transformation and secret information

for a security service

**MODEL FOR NETWORK ACCESS SECURITY**




This document is available on studocu
Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

Using this model requires us to:

– select appropriate gatekeeper functions to identify users

– implement security controls to ensure only authorized users access designated information or resources

- Trusted computer systems can be used to implement this model

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

**Definition of a Security Policy:**

A security policy is a formal statement of the rules by which people who are given access to an organization's technology and information assets must abide."

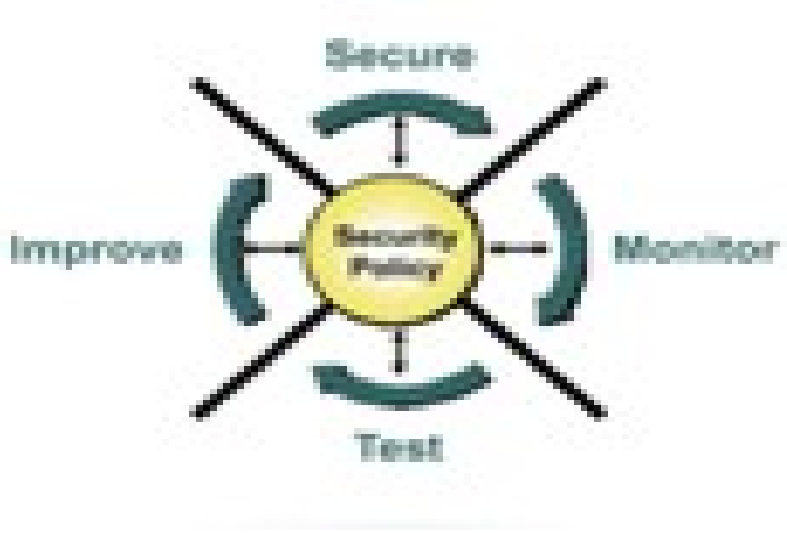
**Why Create a Security Policy?**

- To create a baseline of your current security posture
- To set the framework for security implementation
- To define permitted and non permitted behaviors(actions)
- To help determine necessary tools ( software) and procedures
- To communicate consensus and define roles
- To define how to handle security incidents

**Implementation of a security policy as a continuous process**

Network security is a continuous process built around a security policy it involves four steps which are:

- Step 1: Secure
- Step 2: Monitor
- Step 3: Test
- Step 4: Improve




This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

**Step 1: Secure the Network**

Implement security solutions to stop or prevent unauthorized access or activities , and to protect information. It involves the following processes

- Authentication
- Encryption
- Firewalls
- Vulnerability patching

**Step 2: Monitor Security**

This step detects violations to the security policy. It involves system auditing and real-time intrusion detection. It validates the security implementation in Step 1

**Step 3: Test Security**

This step validates the effectiveness of the security policy through system auditing and vulnerability scanning

**Step 4: Improve Security**

This step uses information from the monitor and test phases to make improvements to the security implementation. It adjusts the security policy as security vulnerabilities and risks are identified

**Task**

*1)What is vulnerability, explain any 5 that can be found on computer network also provide mitigation measures*

*2)Explain five attacks on computer os also provide the mitigation measures*

*3) explain logical and physical security control techniques*

*4) explain* intrusion detection techniques

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

## PHYSICAL SECURITY

Physical access by a person may be allowed depending on payment, authorization, etc. Also there may be one-way traffic of people. These can be enforced by personnel such as a border guards, a doorman, a ticket checker, etc., or with a device such as a turnstile.

There may be fences to avoid circumventing this access control. An alternative of access control in the strict sense (physically controlling access itself) is a system of checking authorized presence, e.g. Ticket controller (transportation). A variant of an access control is exit control, e.g. a shop (checkout) or a country.

In physical security, the term access control refers to the practice of restricting entrance to a property, a building, or a room to authorized persons. Physical access control can be achieved by a human (a guard, bouncer, or receptionist), through mechanical means such as locks and keys, or through technological means such as access control systems like the mantrap. Within these environments, physical key management may also be employed as a means of further managing and monitoring access to mechanically keyed areas or access to certain small assets.

Physical access control is a matter of who, where, and when. An access control system determines who is allowed to enter or exit, where they are allowed to exit or enter, and when they are allowed to enter or exit. Historically this was partially accomplished through keys and locks. When a door is locked only someone with a key can enter through the door depending on how the lock is configured.

**Mechanical locks and keys** do not allow restriction of the key holder to specific times or dates. **Mechanical locks and keys do not provide records** of the key used on any specific door and the keys can easily be copied or transferred to an unauthorized person. When a mechanical key is lost or the key holder is no longer authorized to use the protected area, the locks must be re-keyed.

### Access control system operation

When a credential is presented to a reader, the reader sends the credential's information, usually a number, to a control panel, or a highly reliable processor.

This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

The control panel compares the credential's number to an access control list, grants or denies the presented request, and sends a transaction log to a database.
When access is denied based on the access control list, the door remains locked.
If there is a match between the credential and the access control list, the control panel operates a relay that in turn unlocks the door.

There are three types (factors) of authenticating information in any access control system:

- something the user knows, e.g. a password, pass-phrase or PIN
- something the user has, such as smart card
- something the user is, such as fingerprint, verified by biometric measurement

Passwords are a common means of verifying a user's identity before access is given to information systems. In addition, a fourth factor of authentication is now recognized: someone you know, where another person who knows you can provide a human element of authentication in situations where systems have been set up to allow for such scenarios

**Physical security measures**

The most essential security measures one should implement in an organization include:

**1: Lock up the server room**

Even before you lock down the servers, in fact, before you even turn them on for the first time, you should ensure that there are good locks on the server room door. Of course, the best lock in the world does no good if it isn't used, so you also need policies requiring that those doors be locked any time the room is unoccupied, and the policies should set out who has the key or key-code to get in.

The server room is the heart of your physical network, and someone with physical access to the servers, switches, routers, cables and other devices in that room can do enormous damage.

**2: Set up surveillance**

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

Locking the door to the server room is a good first step, but someone could break in, or someone who has authorized access could misuse that authority. You need a way to know who goes in and out and when. A log book for signing in and out for example, is the most elemental way to accomplish this, however, it has a lot of drawbacks. A person with malicious intent is likely to just bypass it.

**3: Make sure the most vulnerable devices are in that locked room**

Remember, it's not just the servers you have to worry about. A hacker can plug a laptop into a hub and use sniffer software to capture data traveling across the network. Make sure that as many of your network devices as possible are locked in the server room, or if they need to be in a different area, it should be in a locked closet elsewhere in the building.

**4: Use rack-mount servers**

Rack mount servers not only take up less server room space; they are also easier to secure. They can easily be locked into closed racks that, once loaded with several servers, can then be bolted to the floor, making the entire package almost impossible to move, much less to steal.

**5: Don't forget the workstations**

Hackers can use any unsecured computer that's connected to the network to access or delete information that's important to the business. Workstations at unoccupied desks or in empty offices (such as those used by employees who are on vacation or have left the company and not yet been replaced) or at locations easily accessible to outsiders, such as the front receptionist's desk, are particularly vulnerable.

This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

**6: Keep intruders from opening the case**

Many computers come with case locks to prevent opening the case without a key. You can get locking kits from a variety of sources for very low cost, such as the one at Innovative Security Products.

**7: Protect the portables**

Laptops and handheld computers pose special physical security risks. A thief can easily steal the entire computer, including any data stored on its disk as well as network logon passwords that may be saved.

**Handhelds** can be locked in a drawer or safe or just slipped into a pocket and carried on when you leave the area. Motion sensing alarms such as the one at SecurityKit.com are also available to alert you if your portable is moved.

For portables that contain sensitive information, full disk encryption, biometric readers, and software that "phones home" if the stolen laptop connects to the Internet can supplement physical precautions.

**8: Pack up the backups**

Backing up important data is an essential element in disaster recovery; however, the information on those backup tapes, disks, or discs can be stolen and used by someone outside the company. Many IT administrators keep the backups next to the server in the server room. They should be locked in a drawer or safe at the very least. A set of backups should be kept off site, and you must take care to ensure that they are secured in that offsite location.

**9: Disable the drives**

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

If you don't want employees to copy company information to removable media, you can disable or remove floppy drives, USB ports, and other means of connecting external drives. Simply disconnecting the cables may not deter technically savvy workers. Some organizations go so far as to fill ports with glue or other substances to permanently prevent their use, although there are software mechanisms that disallow it. Disk locks, such as the one at SecurityKit.com, can be inserted into floppy drives on those computers that still have them to lock out other diskettes.

**10: Protect your printers**

You might not think about printers posing a security risk, but many of today's printers store document contents in their own on-board memories. If a hacker steals the printer and accesses its memory, he or she may be able to make copies of recently printed documents. Printers like servers and workstations have the ability to store important information and should be located in secure locations and bolted down so that nobody can walk off with them.

Physical controls support and work with administrative and technical (logical) controls to supply the right degree of access control.

**Physical Control Components**

**Network Segregation**

Network segregation can be carried out through physical and logical means. A section of the network may contain web servers, routers, and switches, and yet another network portion may have employee workstations.

Each area would have the necessary physical controls to ensure that only the permitted individuals have access into and out of those sections.

**i)Perimeter Security**

The implementation of perimeter security depends upon the company and the security requirements of that environment.

This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

One environment may require employees to be authorized by a security guard by showing a security badge that contains picture identification before being allowed to enter a section. Another environment may require no authentication process and let anyone and everyone into different sections.

Perimeter security can also encompass closed-circuit TVs that scan the parking lots and waiting areas, fences surrounding a building, lighting of walkways and parking areas, motion detectors, sensors, alarms, and the location and visual appearance of a building. These are examples of perimeter security mechanisms that provide physical access control by providing protection for individuals, facilities, and the components within facilities.

**ii) Computer Controls**

Each computer can have physical controls installed and configured, such as locks on the cover so that the internal parts cannot be stolen, the removal of the floppy and CD-ROM drives to prevent copying of confidential information, or implementation of a protection device that reduces the electrical emissions to thwart attempts to gather information through airwaves.

**iii) Work Area Separation**

Some environments might dictate that only particular individuals can access certain areas of the facility.

**iv) Data Backups**

Backing up data is a physical control to ensure that information can still be accessed after an emergency or a disruption of the network or a system.

**v) Cabling**

There are different types of cabling that can be used to carry information throughout a network. Some cable types have sheaths that protect the data from being affected by the electrical interference of other devices that emit electrical signals.

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

Some types of cable have protection material around each individual wire to ensure that there is no crosstalk between the different wires. All cables need to be routed throughout the facility in a manner that is not in people's way or that could be exposed to any danger of being cut, burnt, crimped, or eavesdropped upon.

**vi) Control Zone**

It is a specific area that surrounds and protects network devices that emit electrical signals. These electrical signals can travel a certain distance and can be contained by a specially made material, which is used to construct the control zone.

The control zone is used to resist penetration attempts and disallow sensitive information to "escape" through the airwaves. A control zone is used to ensure that confidential information is contained and to hinder intruders from accessing information through the airwaves.
Companies that have very sensitive information would likely protect that information by creating control zones around the systems that are processing that information

**Examples of Physical Control**

(i) Fences
(ii) Locks
(iii) Badge system
(iv) Security guard
(v) Biometric system
(vi) Mantrap doors
(vii) Lighting
(viii) Motion detectors

- Closed-circuit TVs
- Alarms
- Backups

This document is available on studocu
Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

**DATABASE SECURITY**

Database security concerns the use of a broad range of information security controls to protect databases (potentially including the data, the database applications or stored functions, the database systems, the database servers and the associated network links) against compromises of their ***confidentiality, integrity and availability.***

It involves various types or categories of controls, such as technical, procedural/administrative and physical. Database security is a specialist topic within the broader realms of computer security, information security and risk management.

**Security risks to database systems include:**

- ***Unauthorized or unintended activity or misuse by authorized database users***, database administrators, or network/systems managers, or by unauthorized users or hackers (e.g. inappropriate access to sensitive data, metadata or functions within databases, or inappropriate changes to the database programs, structures or security configurations);
- ***Malware infections*** causing incidents such as unauthorized access, leakage or disclosure of personal or proprietary data, deletion of or damage to the data or programs, interruption or denial of authorized access to the database, attacks on other systems and the unanticipated failure of database services;
-

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

- ***Overloads, performance*** constraints and capacity issues resulting in the inability of authorized users to use databases as intended;
- ***Physical damage*** to database servers caused by computer room fires or floods, overheating, lightning, accidental liquid spills, static discharge, electronic breakdowns/equipment failures and obsolescence;
- ***Design flaws and programming*** bugs in databases and the associated programs and systems, creating various security vulnerabilities (e.g. unauthorized privilege escalation), data loss/corruption, performance degradation etc.;
- ***Data corruption and/or loss*** caused by the entry of invalid data or commands, mistakes in database or system administration processes, sabotage/criminal damage etc.

Many layers and types of information security control are appropriate to secure a database. These may include:

- Access control
- Auditing
- Authentication
- Encryption
- Integrity controls
- Backups
- Application security – softwares to monitor

**APPLICATIONS AND SYSTEMS DEVELOPMENT SECURITY**

**Security Development Controls**

1. **Administration Control**

The administrative controls are defined by the top management in an organization.

Examples of Administrative Controls

(i) Security policy
(ii) Monitoring and supervising
(iii) Separation of duties
(iv) Job rotation

This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

(v) Information classification

(vi) Personnel procedures

(vii) Investigations

(viii) Testing

(ix) Security-awareness and training

**2. Policy and Procedures**

(i) A security policy is a high-level plan that states management's intent pertaining to how security should be practiced within an organization. It also includes actions are acceptable, and what level of risk the company is willing to accept. This policy is derived from the laws, regulations, and business objectives that shape and restrict the company.

(ii) The security policy provides direction for each employee and department regarding how security should be implemented and followed. It also includes the repercussions for non-compliance. Procedures, guidelines, and standards provide the details that support and enforce the company's security policy.

**3. Personnel Controls**

(i) Personnel controls indicate how employees are expected to interact with security mechanisms, and address noncompliance issues pertaining to these expectations.

(ii) *Change of Status*: These controls indicate what security actions should be taken when an employee is hired, terminated, suspended, moved into another department, or promoted.

(iii) *Separation of duties*: The separation of duties should be enforced so that no one individual can carry out a critical task alone that could prove to be detrimental to the company.

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)

4. **Supervisory Structure**

   Management must construct a supervisory structure which enforces management members to be responsible for employees and take a vested interest in their activities. If an employee is caught hacking into a server that holds customer credit card information, that employee and her supervisor will face the consequences?

5. **Security-Awareness Training**

   This control helps users/employees understand how to properly access resources, why access controls are in place and the ramification for not using the access controls properly.

6. **Testing**

   This control states that all security controls, mechanisms, and procedures are tested on a periodic basis to ensure that they properly support the security policy, goals, and objectives set for them.

The testing can be a drill to test reactions to a physical attack or disruption of the network, a penetration test of the firewalls and perimeter network to uncover vulnerabilities, a query to employees to gauge their knowledge, or a review of the procedures and standards to make sure they still align with business or technology changes that have been implemented.

This document is available on studocu

Downloaded by Tarqueen Jepkoech (tarqueentech@gmail.com)